

SOC Automation Project

Installation, Configuration & User Manual

Multi-tenant threat detection, correlation & AI-assisted reporting

Built by Mohit

1. Overview & Architecture

The SOC Automation Project ingests security logs (email, Windows Security/Sysmon events, PowerShell script-block logs, and cloud/AD sign-in logs), runs them through 9 independent detection modules, correlates related alerts into multi-stage incidents, and produces an executive report with an AI-generated summary and MITRE ATT&CK mapping.

Four layers

- Ingestion - reads/normalizes logs from every source into one JSON event schema.
- Detection - 9 modules, each independently flags one class of threat.
- Correlation ('The Brain') - links alerts across modules that share a user/host/IP/IOC within a time window into one incident.
- Reporting - builds the HTML report and the AI executive summary (Item 10).

Detection modules

- Phishing email detection (SPF/DKIM/DMARC + risky URLs/attachments)
- VirusTotal reputation checking (hashes/domains, cached, rate-limited)
- Brute force detection (EID 4625/4624)
- LSASS / Mimikatz credential dumping (Sysmon EID 10)
- Malicious PowerShell detection (EID 4104, -EncodedCommand decoding)
- Ransomware detection (shadow-copy deletion, mass file encryption)
- Persistence detection (scheduled tasks EID 4698, registry Run keys)
- Lateral movement detection (admin shares, PsExec, multi-host logons)
- Impossible travel detection (GeoIP + travel-speed physics)

Multi-tenancy

Every client ("tenant") gets a physically separate SQLite database, sample-data folder, and reports folder. There is no shared table and no tenant_id column to get wrong - Client A's data cannot leak into Client B's dashboard because it is never loaded into the same file.

2. Installation

Option A - Docker (recommended)

This is the fastest path for a client machine. Requires Docker Desktop.

```
docker compose up -d --build
```

The web dashboard is then available at:

```
http://localhost:8501
```

To run the detection pipeline for a specific tenant from the command line instead:

```
docker compose run --rm pipeline --tenant acme_corp
```

Option B - Local Python install

```
python -m venv .venv
.venv\Scripts\activate      (Windows)
source .venv/bin/activate   (Linux/Mac)
pip install -r requirements.txt streamlit fpdf2
```

Run the pipeline once, then launch the dashboard:

```
python main.py --tenant demo
streamlit run dashboard/app.py
```

3. Configuring API Keys

All keys are optional - every module has an offline fallback so the system is fully usable for a demo or evaluation with zero paid API access. Set keys as environment variables (recommended) or in config.yaml.

VirusTotal (hash/domain reputation)

- Get a free API key at virustotal.com (4 requests/minute on the free tier).
- Set environment variable `VT_API_KEY`, or edit `virustotal.api_key` in config.yaml.
- Without a key: the module uses a small offline blocklist so it still runs end-to-end.

Anthropic / Claude (AI-generated executive summary)

- Get an API key from console.anthropic.com.
- Set environment variable `ANTHROPIC_API_KEY`.
- Without a key: the report falls back automatically to a clear template-based summary - report generation never fails because of this.

IPinfo (optional, real GeoIP for Impossible Travel)

- Only needed to resolve real source IPs to city/lat/lon in production.
- Set `impossible_travel.ipinfo_api_key` in config.yaml.
- The bundled sample data already carries city/lat/lon, so this module works fully offline for demos.

Security note

Never commit real API keys to source control. Use environment variables or a secrets manager in production.

4. Multi-Tenancy - Onboarding a New Client

Add one entry to config/tenants.yaml:

```
tenants:
  - id: "new_client"
    name: "New Client Ltd"
    access_code: "choose-a-code"
```

That's it. The next pipeline run or dashboard login for 'new_client' automatically creates its own isolated database at data/new_client/soc.db, its own sample-data folder, and its own reports folder. No other configuration file needs to change.

Production note

The dashboard's tenant + access-code screen is a demo-grade gate, not enterprise authentication. For real multi-client production use, wire up Streamlit's native `st.login()` with your identity provider (SSO/OIDC) and map the authenticated user's organization claim to the tenant ID.

5. Running the Detection Pipeline (CLI)

```
python main.py --tenant acme_corp
python main.py --tenant acme_corp --no-sample-data    # reuse existing logs
python main.py --tenant acme_corp --no-genai          # force template summary
python main.py --list-tenants
```

Each run: ingests logs -> runs all 9 detectors -> stores alerts in that tenant's database -> re-runs correlation -> writes a fresh HTML report to reports/<tenant>/.

6. Using the Web Dashboard

- Sign in by choosing your organization and entering its access code.
- Sidebar: 'Run detection pipeline now' re-runs ingestion + detection + correlation + reporting for your organization on demand.
- Overview tab: KPI counts, severity distribution, alerts-by-module, and a timeline.
- Incidents tab: correlated multi-stage attack chains with a step-by-step narrative.
- Alerts tab: every individual alert, filterable by severity and detector.
- IOCs tab: every indicator of compromise (IP, domain, hash, URL) extracted so far.
- Reports tab: download any previously generated HTML report.

7. Reading the Report

Severity levels

- Critical - confirmed or near-certain compromise; act immediately.
- High - strong indicator of malicious activity; triage same day.
- Medium - suspicious but not conclusive; review during normal triage.
- Low - informational; monitor for recurrence.

Correlated incidents vs. standalone alerts

An 'incident' means 2 or more different detectors fired on the same user, host, IP, or IOC within the configured time window - this is much higher-confidence evidence of a real, active intrusion than any single alert, because it shows a pattern across multiple independent detection methods.

MITRE ATT&CK mapping

Every alert carries a MITRE ATT&CK technique ID and tactic (e.g. T1110 / Credential Access). The report's MITRE table shows which stages of a real attack lifecycle (Initial Access, Execution, Persistence, Lateral Movement, Impact, etc.) were observed.

IOCs (Indicators of Compromise)

IPs, domains, file hashes and URLs extracted from alerts - use these to block at your firewall/EDR/email gateway.

8. Troubleshooting / FAQ

The AI executive summary says 'Template-Based' instead of 'AI-Generated'

ANTHROPIC_API_KEY is not set in the environment, or the API call failed. Check the key and your network access; the report still generates correctly either way.

VirusTotal alerts aren't appearing

Without VT_API_KEY set, only indicators in the offline blocklist (config.yaml -> virustotal.offline_blocklist_hashes/domains) will be flagged. This is expected in demo mode.

I ran the pipeline twice and got duplicate-looking alerts

Each run re-ingests the sample data and re-inserts alerts by their unique ID; use --no-sample-data to reuse the same logs instead of regenerating new random background noise each time.

Docker: dashboard container can't see my data after a restart

Confirm the data/, sample_data/, reports/, and config/ folders are mounted as volumes in docker-compose.yml (they are, by default) - this is what makes data persist across container rebuilds.